



Chapter 15 – SQL Injection (SQLi)



Introduction to SQL Injection



What is SQL (Structured Query Language)?

SQL (Structured Query Language) is the standard language used to communicate with relational databases. It allows applications to store, retrieve, update, and manage data efficiently.

◆ Why Do We Use SQL?

Almost every modern application stores data in a database:

- Instagram stores user profiles and posts.
- Facebook stores messages and friend lists.
- Banking applications store account details and transactions.
- E-commerce websites store product and customer information.

SQL is used to interact with this data.

◆ Common SQL Operations

Command Purpose

SELECT	Retrieve data
INSERT	Add new data
UPDATE	Modify existing data
DELETE	Remove data

Example:

```
SELECT name, email FROM users WHERE id = 1;
```

This query retrieves the name and email of the user whose ID is 1.

Database Keys

1 Primary Key (PK)

Definition

A Primary Key uniquely identifies every record (row) in a database table.

Characteristics

- ✓ Must be unique
- ✓ Cannot be NULL
- ✓ Only one primary key per table

Example

Student_ID	Name	Age
1	John	20
2	Alice	21

Here:

Student_ID = Primary Key

No two students can have the same Student_ID.



Daily Life Example

Think of your Aadhaar Number.

Millions of people may have the same name, but everyone has a unique Aadhaar Number.

Aadhaar Number = Primary Key

2 Foreign Key (FK)

Definition

A Foreign Key creates a relationship between two tables.

It references the Primary Key of another table.

Example

Students Table

Student_ID Name

1	John
2	Alice

Marks Table

Mark_ID Student_ID Subject Marks

1	1	Math	85
2	1	English	90
3	2	Math	75

Here:

Student_ID in Marks Table = Foreign Key

It connects the Marks table with the Students table.



Daily Life Example

Your Bank Account is linked to your Customer ID.

Customer ID acts like a Foreign Key connecting different records.

3 Candidate Key

Definition

Any column that can uniquely identify a record is called a Candidate Key.

A table can have multiple Candidate Keys.

One of them becomes the Primary Key.

Example

User_ID Email

101	john@gmail.com
-----	----------------

Both User_ID and Email are unique.

Therefore:

- User_ID = Candidate Key
- Email = Candidate Key

One of them can be selected as the Primary Key.

What is SQL Injection (SQLi)?

Definition

SQL Injection is one of the most dangerous Web Application Vulnerabilities.

It occurs when an application directly inserts user input into SQL queries without proper validation.

Attackers inject malicious SQL statements to manipulate database operations.

Goals of SQL Injection

An attacker can:

 Bypass authentication

 Read sensitive information

 Modify data

 Delete records

 Access hidden databases

 Execute system commands (in advanced cases)

 Gain complete control over the database

Why SQL Injection Happens

Root Causes

1. Poor Input Validation

User input is accepted without checking.

2. Dynamic Query Building

Developers concatenate user input directly into SQL queries.

3. No Prepared Statements

Queries are created using string concatenation.

4. Outdated Software

Old applications often contain SQL Injection vulnerabilities.

5. Weak Error Handling

Database errors reveal useful information to attackers.

How SQL Injection Works

Step-by-Step Process

Step 1

Attacker finds a vulnerable input field:

- Login page
- Search bar
- Contact form
- URL parameter

Step 2

Malicious SQL input is entered.

Step 3

Application directly includes the input inside a query.

Step 4

Database executes the query.

Step 5

Attacker gains unauthorized access or retrieves data.

Daily Life Example

Imagine a security guard asks:

What is your name?

Expected answer:

John

But instead someone tricks the guard with unexpected instructions hidden inside the answer.

Similarly, SQL Injection tricks the database into executing unintended commands.

Types of SQL Injection

Error-Based SQL Injection

Definition

This technique relies on database error messages.

Attackers intentionally trigger errors and study the responses.

Purpose

To discover:

- Number of columns
- Database names
- Table names

- Database structure

Example Concept

Attacker sends invalid input.

Database returns:

Unknown Column

From this error the attacker learns how the database is structured.

Prevention

- ✓ Hide database errors
 - ✓ Use custom error pages
 - ✓ Parameterized queries
-

2 Union-Based SQL Injection

Definition

Uses the SQL UNION operator to combine results from multiple queries.

Purpose

Retrieve information from other database tables.

Example Scenario

A product page normally displays product information.

An attacker manipulates the query and attempts to combine results from another table containing user information.

Prevention

- ✓ Prepared Statements
 - ✓ Least Privilege Principle
 - ✓ Input Validation
-

3 Blind SQL Injection (Boolean-Based)

Definition

Sometimes websites do not display errors.

The attacker tests conditions that return:

- TRUE
- FALSE

Then observes website behavior.

Example

Condition 1:

TRUE

Website loads normally.

Condition 2:

FALSE

Website behaves differently.

From these differences attackers infer information.

Prevention

- ✓ Prepared Statements
- ✓ Generic Error Messages
- ✓ WAF Protection

4 Time-Based Blind SQL Injection

Definition

No visible output exists.

Instead attackers observe response times.

Example

A condition causes the server to delay its response.

If the page responds slowly, the attacker learns the condition was true.

Prevention

- ✓ Prepared Statements
 - ✓ Database Monitoring
 - ✓ Query Timeout Restrictions
-

SQL Injection Testing Tools

sqlmap

What is sqlmap?

sqlmap is an open-source penetration testing tool that automates:

- SQL Injection detection
- Database enumeration
- Vulnerability verification

Supported Databases

- MySQL
- Oracle
- PostgreSQL
- Microsoft SQL Server
- SQLite

Features

- ✓ Database Discovery
- ✓ Table Discovery
- ✓ Column Enumeration
- ✓ Data Extraction
- ✓ Vulnerability Detection

Practice Website

A commonly used legal training website for learning SQL Injection concepts is:

<http://testphp.vulnweb.com>

Use only authorized training environments and labs.

Important sqlmap Options

Option	Purpose
--url	Target URL
--crawl	Crawl website pages
--level	Detection level
--risk	Risk level
--technique	SQLi testing techniques
--dbs	Enumerate databases
--tables	Enumerate tables
--columns	Enumerate columns
--schema	Show database schema
--dump	Export table contents
--batch	Use default options
--flush-session	Clear previous session
--wizard	Beginner-friendly mode

Real Impact of SQL Injection

A successful SQL Injection attack may lead to:

-  Account Takeover
-  Financial Data Theft
-  User Information Exposure
-  Database Deletion
-  Data Modification
-  Business Disruption
-  Full System Compromise

SQL Injection Prevention Techniques

1 Parameterized Queries (Prepared Statements)

Best Defense

User input remains separate from SQL code.

Benefits

-  Prevents query manipulation
-  Industry standard protection

2 Input Validation

Allow only expected input.

Examples:

- Numbers only for IDs
 - Valid email format for emails
 - Fixed character limits
-

3 Input Sanitization

Remove dangerous characters before processing.

Examples:

'
"
;
--
#

4 Stored Procedures

Use predefined SQL procedures instead of dynamic queries.

Benefits:

- ✓ Better security
 - ✓ Reduced attack surface
-

5 Principle of Least Privilege

Database accounts should have only required permissions.

Example:

- ✗ Application account should not have database administrator privileges.
 - ✓ Give only Read/Write access if needed.
-

6 Secure Error Handling

Never show database errors to users.

Bad Example:

MySQL Error near line 1

Good Example:

Something went wrong. Please try again later.

7 Web Application Firewall (WAF)

Popular WAF Solutions:

- [Cloudflare](#)
- [AWS WAF](#)
- [Akamai](#)
- [ModSecurity](#)

Benefits:

- ✓ Filters malicious requests
 - ✓ Blocks SQL Injection patterns
 - ✓ Protects web applications
-

8 Security Audits and Vulnerability Scanning

Regularly perform:

- Vulnerability Assessments
 - Penetration Testing
 - Source Code Reviews
 - Patch Management
-

SQL Injection Summary

Topic	Description
SQL	Language used to communicate with databases
SQL Injection	Injection of malicious SQL into vulnerable applications
Primary Key	Unique identifier for records
Foreign Key	Creates relationship between tables
Candidate Key	Potential unique identifiers
Error-Based SQLi	Uses database errors
Union-Based SQLi	Uses UNION operator
Blind SQLi	Uses True/False conditions
Time-Based SQLi	Uses response delays
sqlmap	Automated SQL Injection testing tool
Major Risks	Data theft, login bypass, database compromise
Best Defense	Prepared Statements + Input Validation + WAF

Interview Question

Q. What is SQL Injection and why is it dangerous?

Answer:

SQL Injection is a web application vulnerability where an attacker injects malicious SQL statements into application inputs. It is dangerous because it can allow attackers to bypass authentication, access sensitive data, modify or delete records, compromise databases, and potentially gain complete control over backend systems if proper security controls are not implemented. 